

Assignment

Vehicle Service and Maintenance Tracker

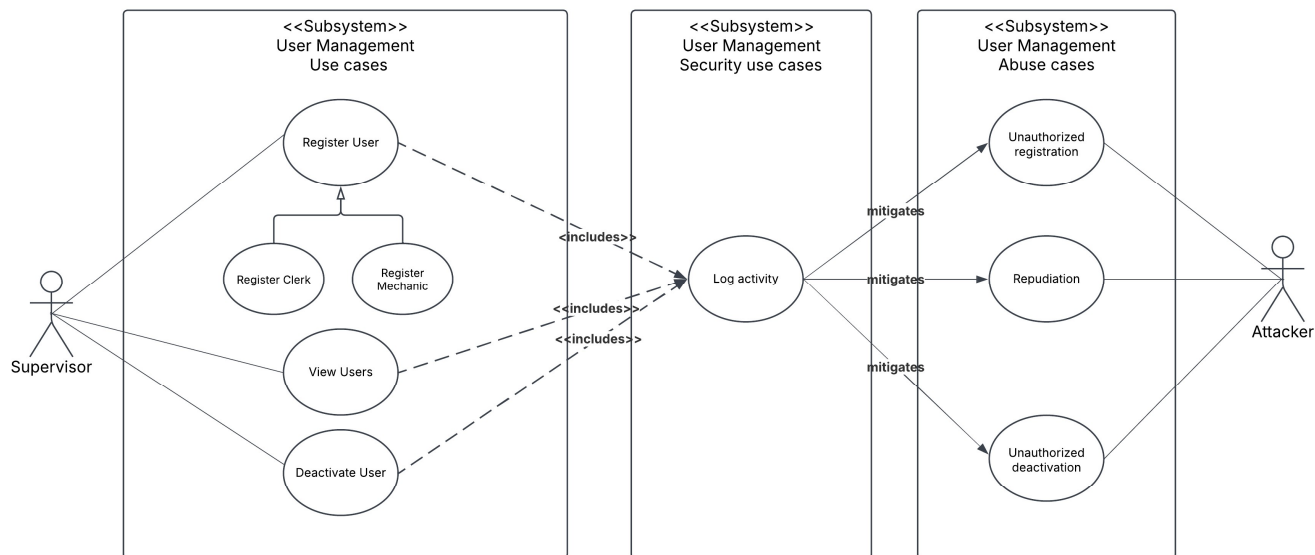
done by: Abdulla Moulana, Mohammed Albustami

Instructor: Hussam Fetyan

Table of Contents

Part 1 - Requirements.....	3
Part 2 - Design	20
Modularize the application	20
UML Class Diagram	20
Decompose the application for security.....	21
User roles of the app.....	21
Main processes and Data stores	21
Trust Level	22
External Dependencies	22
Entry/Exit points	22
Assets	22
Data Flow Diagrams	23
Determine and Rank Threats	26
STRIDE	26
DREAD	26
Determine Countermeasures and Mitigation.....	27
Part 4 – Testing	30

Part 1 - Requirements



Use case Id:	UM-001
Name:	Register user
Created By/Author:	Abdulla Moulana, Mohammed Albustami
Date Created:	24/03/2025
Actor:	Supervisor
Description/Summary:	The Supervisor registers a new employee (Clerk or Mechanic) into the system with his name, role etc
Preconditions:	A Supervisor must be logged in to use this feature and must have the necessary permissions associated with his account
Postconditions:	A new user account is created in the database for using the application An audit log entry is recorded
Normal course of events:	Supervisor selects "Register User" from the User Management Interface, enters user details (name, role etc.) and clicks register
Exceptions:	If the user already exists, an error is displayed If any required fields are empty or wrong
Acceptance Criteria:	The user is registered and the user can log in

Use case Id:	UM-002
Name:	Deactivate user
Created By/Author:	Abdulla Moulana, Mohammed Albustami
Date Created:	24/03/2025
Actor:	Supervisor
Description/Summary:	The Supervisor deactivates an employee's account, denying further access to the system
Preconditions:	A Supervisor must be logged in to use this feature and must have the necessary permissions associated with his account The user account getting deactivated must exist
Postconditions:	The user account is deactivated and cannot be accessed An audit log entry is recorded
Normal course of events:	Supervisor selects "Deactivate User" from the User Management Interface, selects user, and clicks deactivate
Exceptions:	If the target user is a Supervisor account If the user does not exist, an error is displayed
Acceptance Criteria:	The user account is deactivated and the user cant log in

Use case Id:	UM-003
Name:	View Users
Created By/Author:	Abdulla Moulana, Mohammed Albustami
Date Created:	24/03/2025
Actor:	Supervisor
Description/Summary:	The Supervisor deactivates an employee's account, denying further access to the system
Preconditions:	A Supervisor must be logged in to use this feature and must have the necessary permissions associated with his account
Postconditions:	User list is displayed with their name and role
Normal course of events:	Supervisor selects "View Users" from the User Management Interface
Exceptions:	If no users exist, display "No users found."
Acceptance Criteria:	Supervisor sees a up-to-date user list.

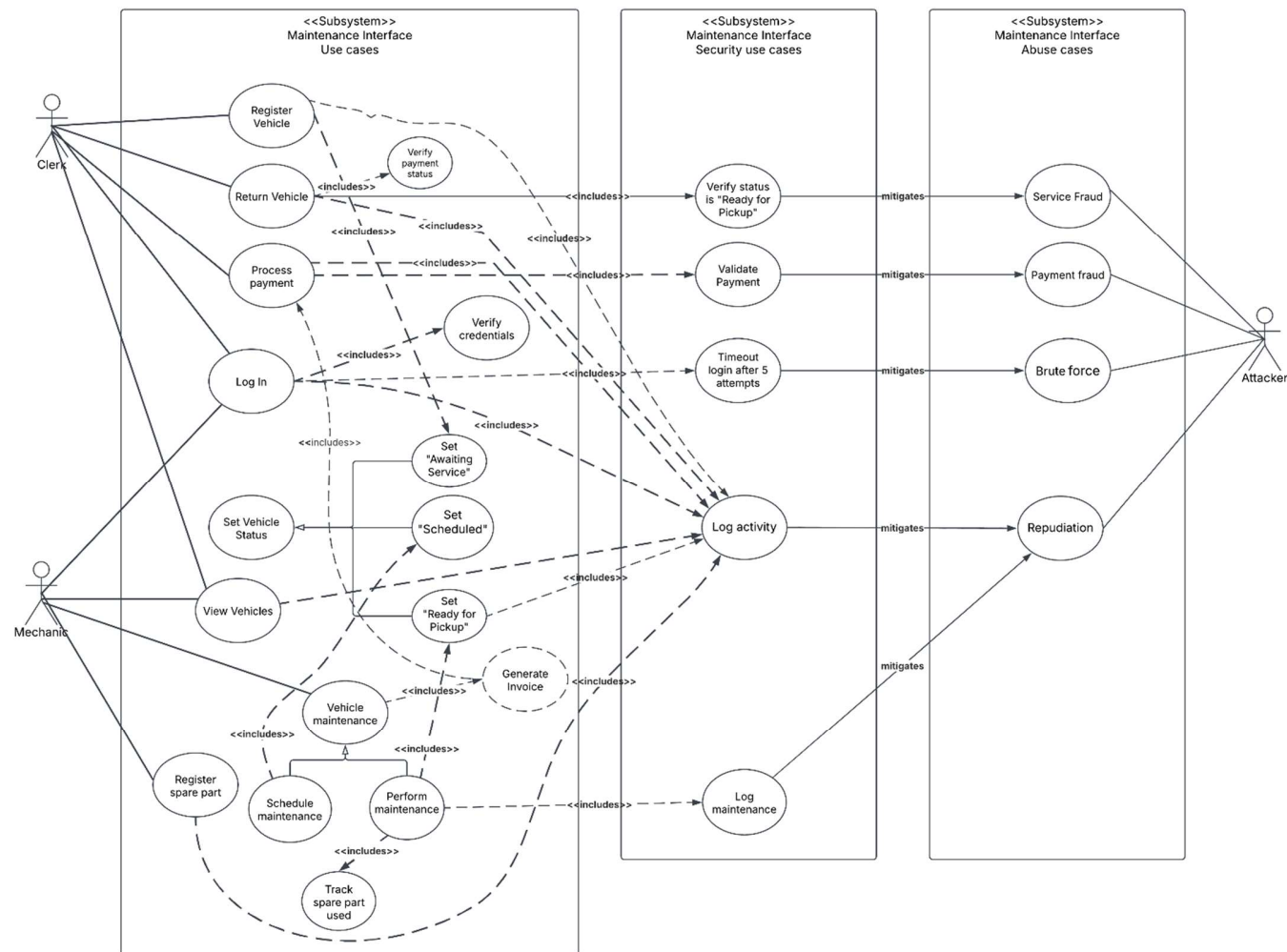
Use case Id:	SUM-001
Name:	Log activity
Created By/Author:	Abdulla Moulana, Mohammed Albustami
Date Created:	24/03/2025
Actor:	App/System
Description/Summary:	Ensures all critical user management activities are logged and stored securely for security and compliance purposes and also for repudiation
Preconditions:	A security-related action (Register User or Deactivate User) is performed. The system logging service must be operational.
Postconditions:	An audit log entry is created with timestamps, user details, and the performed action
Normal course of events:	After the related action is performed, the system records the action, the user and the time and is stored in the database.
Exceptions:	None
Acceptance Criteria:	Successfully logged and stored in the database with al the details

Abuse case Id:	AUM-001
Name:	Unauthorized Registration
Created By/Author:	Abdulla Moulana, Mohammed Albustami
Date:	24/03/2025
Priority:	High
Scope:	User Management System
Development Environment:	Desktop Application
Mis-actors:	Malicious Supervisor or Account Stolen
Access Right Levels:	High Level System Users and System Admin
Point of Entry:	User Management Interface
Security Attributes Affected:	Confidentiality and Integrity
Description:	An attacker registers fake users in the system, potentially leading to fraud and/or unauthorized access
Sophistication:	Requires access to a Supervisor's account to access the User Management module
Preconditions:	The account logged in must be a Supervisor account level
Assumptions:	Employee information is not cross-checked with HR records by the system

Postconditions:	An unauthorized user gains access to the system The fraudulent account could be used for illicit activities.
Related Use Cases:	UM-001 SUM-001
Related Threats:	Insider Threat Data Manipulation Identity Theft
Exceptions:	N/A
Acceptance Criteria:	An unauthorized user gains access to the system and can perform tasks that are fraudulent

Abuse case Id:	AUM-002
Name:	Unauthorized Deactivation
Created By/Author:	Abdulla Moulana, Mohammed Albustami
Date:	24/03/2025
Priority:	High
Scope:	User Management System
Development Environment:	Desktop Application
Mis-actors:	Malicious Supervisor or Account Stolen
Access Right Levels:	High Level System Users and System Admin
Point of Entry:	User Management Interface
Security Attributes Affected:	Availability
Description:	An attacker deactivates users in the system, denying further access to the system
Sophistication:	Requires access to a Supervisor's account to access the User Management module
Preconditions:	The account logged in must be a Supervisor account level
Assumptions:	Intent on denial of Service
Postconditions:	A legitimate user loses access to the system Denial of Service
Related Use Cases:	UM-002 SUM-001
Related Threats:	Insider Threat Identity Theft
Exceptions:	N/A
Acceptance Criteria:	An legitimate user loses access to the system and cannot perform work

Abuse case Id:	AUM-003
Name:	Repudiation
Created By/Author:	Abdulla Moulana, Mohammed Albustami
Date:	24/03/2025
Priority:	Medium
Scope:	User Management System
Development Environment:	Desktop Application
Mis-actors:	Malicious Supervisor or Account Stolen
Access Right Levels:	High Level System Users and System Admin
Point of Entry:	User Management Interface
Security Attributes Affected:	Confidentiality
Description:	An attacker views sensitive user lists but later denies doing so
Sophistication:	Requires access to a Supervisor's account to access the User Management module
Preconditions:	The account logged in must be a Supervisor account level
Assumptions:	Attacker may act maliciously
Postconditions:	Attacker views sensitive data
Related Use Cases:	UM-003 SUM-001
Related Threats:	Insider Threat Identity Theft Data leak
Exceptions:	N/A
Acceptance Criteria:	Attacker successfully views user data without a trace



Use case Id:	MI-001
Name:	Register Vehicle
Created By/Author:	Abdulla Moulana, Mohammed Albustami
Date Created:	24/03/2025
Actor:	Clerk
Description/Summary:	Clerk registers a new vehicle into the maintenance system with details like VIN, make, and model
Preconditions:	Clerk must be logged in
Postconditions:	Vehicle is added to the system Invoice is generated
Normal course of events:	Clerk selects "Register Vehicle" and enters the vehicle's details System validates and saves the record
Exceptions:	Duplicate VIN in the database
Acceptance Criteria:	Vehicle is successfully added to the database

Use case Id:	MI-002
Name:	Return Vehicle
Created By/Author:	Abdulla Moulana, Mohammed Albustami
Date Created:	24/03/2025
Actor:	Clerk
Description/Summary:	Clerk returns a serviced vehicle
Preconditions:	Clerk must be logged in Vehicle must be serviced Service is paid for
Postconditions:	Vehicle is returned to the customer and updated in the system that the vehicle is returned
Normal course of events:	Clerk selects Return vehicle and system verifies the preconditions
Exceptions:	Invoice is not paid Vehicle is awaiting service or still in service
Acceptance Criteria:	Vehicle is successfully returned

Use case Id:	MI-002a
Name:	Verify payment status
Created By/Author:	Abdulla Moulana, Mohammed Albustami
Date Created:	24/03/2025
Actor:	App/System
Description/Summary:	When clerk is in the process of returning the car, system checks if all invoices are cleared(payment status is true).
Preconditions:	Clerk must be logged in Vehicle must be serviced Service is paid for
Postconditions:	Vehicle is returned to the customer and updated in the system that the vehicle is returned
Normal course of events:	Clerk selects Return vehicle and system verifies the preconditions
Exceptions:	Invoice is not paid Vehicle is awaiting service or still in service
Acceptance Criteria:	Vehicle is successfully returned

Use case Id:	MI-003
Name:	Process Payment
Created By/Author:	Abdulla Moulana, Mohammed Albustami

Date Created:	24/03/2025
Actor:	Clerk
Description/Summary:	Clerk processes payment for maintenance/services
Preconditions:	Clerk must be logged in Vehicle must be registered Service details must be logged
Postconditions:	Payment is recorded
Normal course of events:	Clerk selects "Process Payments" and selects the payment method A pair of receipt is generated, one for the customer and for record-keeping
Exceptions:	Payment status marked "false"
Acceptance Criteria:	Payment status marked "true"

Use case Id:	SMI-001
Name:	Verify Status is "Ready for Pickup"
Created By/Author:	Abdulla Moulana, Mohammed Albustami
Date Created:	24/03/2025
Actor:	App/System
Description/Summary:	Ensures a vehicle's status is "Ready for Pickup" before releasing to the customer.
Preconditions:	Maintenance tasks are completed
Postconditions:	Vehicle status is validated; release authorized
Normal course of events:	System checks vehicle status and decides whether true or false
Exceptions:	Status is "Awaiting Service", "In Service" or no status is set(default)
Acceptance Criteria:	Only "Ready for Pickup" vehicles are authorized for release

Use case Id:	SMI-002
Name:	Validate payment
Created By/Author:	Abdulla Moulana, Mohammed Albustami
Date Created:	24/03/2025
Actor:	App/System
Description/Summary:	Validates payment authenticity before confirming completion
Preconditions:	Payment details submitted
Postconditions:	Payment is verified and logged
Normal course of events:	System cross-checks payment with bank/POS. It then approves if valid
Exceptions:	Declined Transactions Fraud detection
Acceptance Criteria:	Only legitimate payments are processed

Abuse case Id:	AMI-001
Name:	Service Fraud
Created By/Author:	Abdulla Moulana, Mohammed Albustami

Date:	24/03/2025
Priority:	High
Scope:	Maintenance Interface
Development Environment:	Desktop Application
Mis-actors:	Malicious Clerk
Access Right Levels:	Medium-Level System Users
Point of Entry:	Maintenance Interface -> Return Vehicle
Security Attributes Affected:	Integrity
Description:	Clerk logs fake services to and returns the vehicle
Sophistication:	Requires access to a Clerk's account to access the Maintenance Interface
Preconditions:	Weak oversight in service logging
Assumptions:	None
Postconditions:	Client trust damaged
Related Use Cases:	MI-002 SMI-001
Related Threats:	Insider Fraud
Exceptions:	N/A
Acceptance Criteria:	Fake services are invoiced and paid

Abuse case Id:	AMI-002
Name:	Payment Fraud
Created By/Author:	Abdulla Moulana, Mohammed Albustami
Date:	24/03/2025
Priority:	High
Scope:	Maintenance Interface --> Payment
Development Environment:	Desktop Application
Mis-actors:	Malicious Clerk, Compromised User
Access Right Levels:	Medium/High-Level System Users
Point of Entry:	Maintenance Interface -> Process Payment
Security Attributes Affected:	Integrity, Confidentiality
Description:	An attacker exploits payment processing to: Process fake transactions Manipulate invoice amounts Steal payment details of customer
Sophistication:	Requires access to a Medium/High-Level account to access the Maintenance Interface with permissions to use Process Payment
Preconditions:	Attacker has "Process Payment" privileges
Assumptions:	Clients may not check receipt
Postconditions:	Financial loss for the business/customers
Related Use Cases:	MI-003

	SMI-002
Related Threats:	Insider Fraud Data Theft
Exceptions:	Bank/POS systems flag suspicious activity
Acceptance Criteria:	Payment fraud is successful and attacker evades detection

Use case Id:	MI-004
Name:	Log In
Created By/Author:	Abdulla Moulana, Mohammed Albustami
Date Created:	24/03/2025
Actor:	User (Clerk, Mechanic, Supervisor)
Description/Summary:	User logs into the system with credentials
Preconditions:	User has valid account
Postconditions:	User gains access; failed attempts logged.
Normal course of events:	User enters credentials, system verifies the credentials and user gains access
Exceptions:	Invalid credentials
Acceptance Criteria:	Success: Access granted, Failure: Appropriate error message and back to login page

Use case Id:	MI-004a
Name:	Verify credentials
Created By/Author:	Abdulla Moulana, Mohammed Albustami
Date Created:	24/03/2025
Actor:	App/System
Description/Summary:	App/System checks if credentials are valid and exist in the database
Preconditions:	User has valid account
Postconditions:	User gains access; failed attempts logged.
Normal course of events:	User enters credentials, system verifies the credentials and user gains access
Exceptions:	Invalid credentials
Acceptance Criteria:	Success: Access granted, Failure: Appropriate error message and back to login page

Use case Id:	SMI-003
Name:	Deactivate User After 5 Attempts
Created By/Author:	Abdulla Moulana, Mohammed Albustami
Date Created:	24/03/2025
Actor:	App/System

Description/Summary:	Lock account after 5 failed login attempts
Preconditions:	Username exists 5 consecutive failed logins
Postconditions:	Account locked; admin alerted
Normal course of events:	System logs each failed attempt and when the count reaches 5, account is locked
Exceptions:	None
Acceptance Criteria:	Account locked and admin notified

Abuse case Id:	AMI-003
Name:	Brute Force
Created By/Author:	Abdulla Moulana, Mohammed Albustami
Date:	24/03/2025
Priority:	High
Scope:	Authentication System
Development Environment:	Desktop Application
Mis-actors:	Authentication System
Access Right Levels:	None
Point of Entry:	Login Page
Security Attributes Affected:	Confidentiality
Description:	An attacker is attempting to login by trying multiple combinations of passwords for a username to gain access to a user account
Sophistication:	Low sophistication, many brute force dictionaries and tools available
Preconditions:	Attacker knows a username
Assumptions:	N/A
Postconditions:	Attacker gains access to a legitimate user account
Related Use Cases:	MI-004 SMI-003
Related Threats:	Credential Stuffing Data Breach
Exceptions:	None
Acceptance Criteria:	Attacker gains access to a user account

Use case Id:	MI-005
Name:	Set Vehicle Status
Created By/Author:	Abdulla Moulana, Mohammed Albustami
Date Created:	24/03/2025
Actor:	System/App
Description/Summary:	Update a vehicle's status (Awaiting Service/Scheduled/Ready for Pickup)
Preconditions:	Vehicle is registered in the system
Postconditions:	Status updated

Extensions	"Awaiting Service", "Scheduled", "Ready for Pickup" (children)
Normal course of events:	System/App sets vehicle status after a certain action (example: Vehicle is registered and status is set to 'Awaiting Service')
Exceptions:	None
Acceptance Criteria:	Status is updated in the system

Use case Id:	MI-005a
Name:	Set Vehicle Status: Awaiting Service
Created By/Author:	Abdulla Moulana, Mohammed Albustami
Date Created:	24/03/2025
Actor:	System/App
Description/Summary:	Update a vehicle's status to "Awaiting Service"
Preconditions:	Vehicle is registered in the system
Postconditions:	Status updated
Normal course of events:	System/App sets vehicle status to Awaiting Service
Exceptions:	None
Acceptance Criteria:	Status is updated in the system

Use case Id:	MI-005b
Name:	Set Vehicle Status: In Service
Created By/Author:	Abdulla Moulana, Mohammed Albustami
Date Created:	24/03/2025
Actor:	System/App
Description/Summary:	Update a vehicle's status to "In Service"
Preconditions:	Vehicle is registered in the system
Postconditions:	Status updated
Normal course of events:	System/App sets vehicle status to Awaiting Service
Exceptions:	None
Acceptance Criteria:	Status is updated in the system

Use case Id:	MI-005c
Name:	Set Vehicle Status: Ready for Pickup
Created By/Author:	Abdulla Moulana, Mohammed Albustami
Date Created:	24/03/2025
Actor:	System/App
Description/Summary:	Update a vehicle's status to "Ready for Pickup"
Preconditions:	Vehicle is registered in the system
Postconditions:	Status updated

Normal course of events:	System/App sets vehicle status to Ready for Pickup
Exceptions:	None
Acceptance Criteria:	Status is updated in the system

Use case Id:	SMI-004
Name:	Log activity
Created By/Author:	Abdulla Moulana, Mohammed Albustami
Date Created:	24/03/2025
Actor:	System/App
Description/Summary:	Record user actions with the timestamp and the query used for interacting with the database
Preconditions:	User does an action
Postconditions:	Action logged with timestamp/user
Normal course of events:	System logs the activity after an action
Exceptions:	None
Acceptance Criteria:	The action is logged in the database

Abuse case Id:	AMI-004
Name:	Repudiation
Created By/Author:	Abdulla Moulana, Mohammed Albustami
Date:	24/03/2025
Priority:	Medium
Scope:	Maintenance Interface
Development Environment:	Desktop Application
Mis-actors:	Malicious Clerk and Mechanic
Access Right Levels:	Medium-Level System Users
Point of Entry:	Any action in the app
Security Attributes Affected:	Integrity
Description:	A user does an action but claims he did not do it
Sophistication:	Low sophistication of doing this
Preconditions:	Logs don't capture user/timestamp
Assumptions:	None
Postconditions:	Disputed accountability
Related Use Cases:	MI-001 MI-002 MI-003 MI-004 MI-007b MI-006 MI-009 SMI-004 SMI-005
Related Threats:	Operational Disputes

	Insider Threat
Exceptions:	Audit logs prove action
Acceptance Criteria:	Status change untraceable to user

Use case Id:	MI-006
Name:	Register spare part
Created By/Author:	Abdulla Moulana, Mohammed Albustami
Date Created:	24/03/2025
Actor:	Mechanic
Description/Summary:	Mechanic adds a new spare part to the system inventory database.
Preconditions:	Mechanic has the necessary permissions
Postconditions:	Spare part is added to the database Inventory count is updated
Normal course of events:	Clerk selects "Register Spare Part", enters part's details and clicks save
Exceptions:	Invalid quantity input
Acceptance Criteria:	Database gets updated with part and the quantity

Use case Id:	MI-007
Name:	Vehicle Maintenance
Created By/Author:	Abdulla Moulana, Mohammed Albustami
Date Created:	24/03/2025
Actor:	Mechanic
Description/Summary:	Perform or schedule maintenance for a vehicle
Preconditions:	Vehicle is registered and status is "Awaiting Service."
Postconditions:	Maintenance task is recorded
Extensions	"Schedule maintenance", "Perform maintenance"
Normal course of events:	Mechanic selects vehicle maintenance and then selects one of 2 options
Exceptions:	Invalid quantity input
Acceptance Criteria:	Maintenance history reflects the task

Use case Id:	MI-007a
Name:	Vehicle Maintenance: "Schedule maintenance"
Created By/Author:	Abdulla Moulana, Mohammed Albustami
Date Created:	24/03/2025
Actor:	Mechanic
Description/Summary:	Assign a future maintenance date for a vehicle
Preconditions:	Vehicle is registered and status is "Awaiting Service."
Postconditions:	Maintenance is scheduled in the system calendar

Normal course of events:	Mechanic selects "Schedule maintenance.", chooses date/time and system confirms and makes a record in the schedule table in the database with the date
Exceptions:	Selected date/time has maximum amount of maintenance scheduled
Acceptance Criteria:	Appointment appears in the database

Use case Id:	MI-007b
Name:	Vehicle Maintenance: "Perform maintenance"
Created By/Author:	Abdulla Moulana, Mohammed Albustami
Date Created:	24/03/2025
Actor:	Mechanic
Description/Summary:	Records that maintenance is done
Preconditions:	Vehicle is registered and status is "Scheduled"
Postconditions:	Vehicle status updated to "Ready for Pickup."
Normal course of events:	Mechanic selects "Perform maintenance.", selects the vehicle to perform maintenance on, inputs the details of maintenance done. and system logs the maintenance
Exceptions:	None
Acceptance Criteria:	Maintenance is logged

Use case Id:	MI-008
Name:	Track Spare Part used
Created By/Author:	Abdulla Moulana, Mohammed Albustami
Date Created:	24/03/2025
Actor:	System
Description/Summary:	Records spare parts used during maintenance
Preconditions:	Mechanic selects parts during "Perform Maintenance"
Postconditions:	Parts deducted from inventory
Normal course of events:	The spare parts that were selected in "Perform maintenance" is deducted from the inventory database
Exceptions:	None
Acceptance Criteria:	Spare parts records are updated

Use case Id:	SMI-005
Name:	Log Maintenance
Created By/Author:	Abdulla Moulana, Mohammed Albustami
Date Created:	24/03/2025
Actor:	App/System
Description/Summary:	Records maintenance actions for record keeping and audit trails.

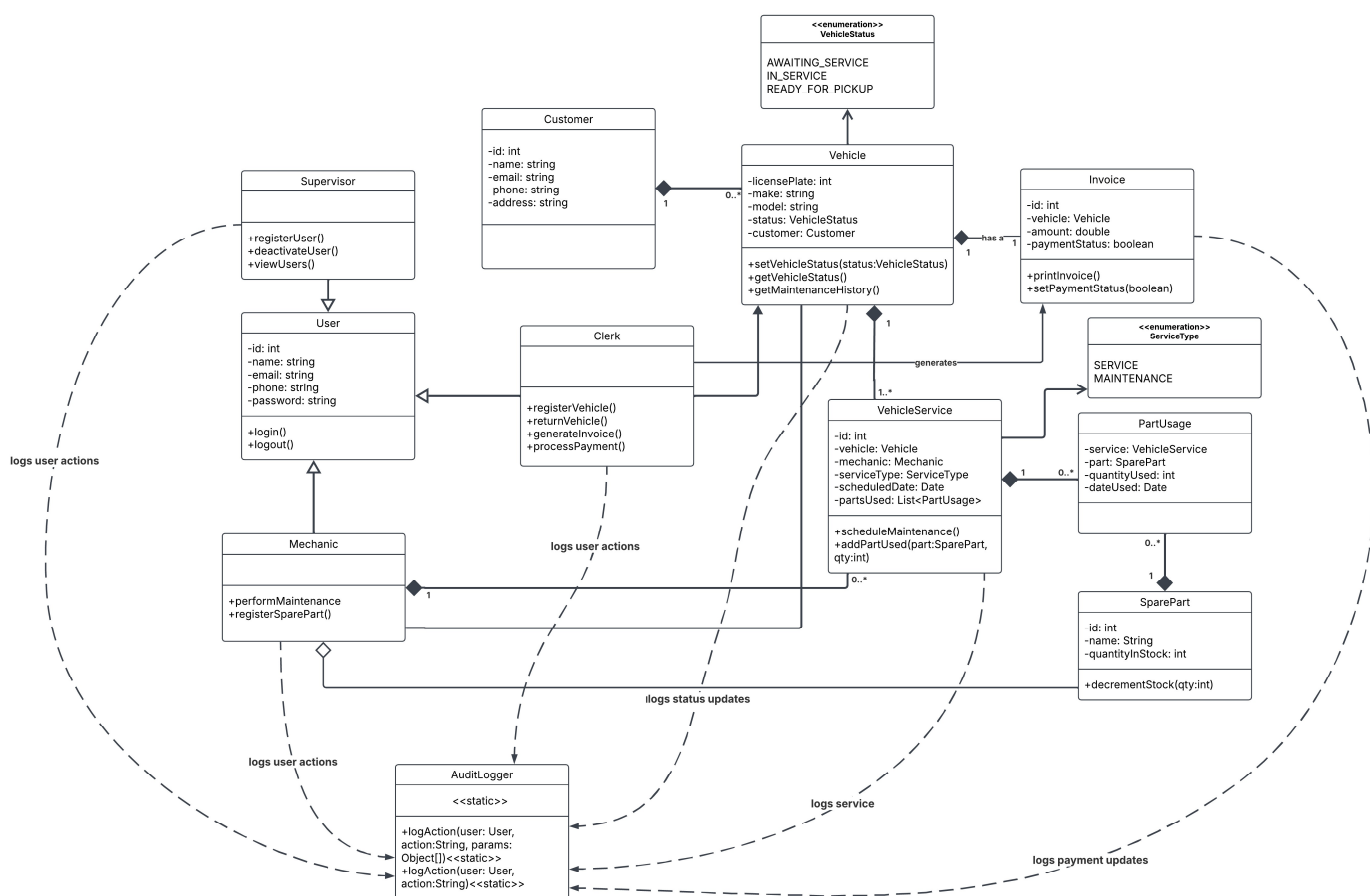
Preconditions:	Mechanic completes "Perform maintenance."
Postconditions:	Maintenance details saved (tasks, mechanic, time)
Normal course of events:	After mechanic submits "Perform maintenance", the system then logs it
Exceptions:	None
Acceptance Criteria:	Logs prove who performed the maintenance and what was done

Use case Id:	MI-009
Name:	View Vehicles
Created By/Author:	Abdulla Moulana, Mohammed Albustami
Date Created:	24/03/2025
Actor:	Clerk, Mechanic
Description/Summary:	Displays all vehicles registered in the database and their status
Preconditions:	A vehicle is registered
Postconditions:	List the vehicles retrieved from the database
Normal course of events:	A user clicks on view vehicles and all vehicles are displayed
Exceptions:	No vehicles are registered Database is down
Acceptance Criteria:	All vehicles are displayed

Part 2 - Design

Modularize the application

UML Class Diagram



Decompose the application for security

User roles of the app

User Role	Description
Supervisor	Manages users and oversees operations.
Clerk	Registers/returns vehicle, processes payments, generates invoice
Mechanic	Performs maintenance, registers spare parts to inventory

Main processes and Data stores

Processes	Description
User Authentication	Login/Logout
User Management	Done by Supervisor
Vehicle Management	Vehicle registered by clerk, vehicle status managed by clerk and mechanic, vehicle service invoice generated by clerk, vehicle maintenance performed by mechanic, and vehicle returned by clerk
Spare parts Management	Registered by mechanic, used by mechanic, and usage tracked by system
Payment Processing	Processed by clerk, the application only records how the payment was made(cash or card), and for updating the payment status
Logging	Application/System logs various actions and changes

Data Stores	Description
User Database	User login credentials, profiles
Vehicle Database	Vehicle details, date of registration and status
Maintenance Database	Records of all maintenance done
Invoice Database	Stores the invoices of vehicles registered and their payment status
Payment Records	Payment History
Logging Database	Records of the actions performed in the app

Trust Level

User	Trust Level
Supervisor	High
Clerk	Medium
Mechanic	Medium

External Dependencies

External Dependency	Description
MySQL	Remote database server with MySQL running on them
JavaFX	An external Java library to make the application UI

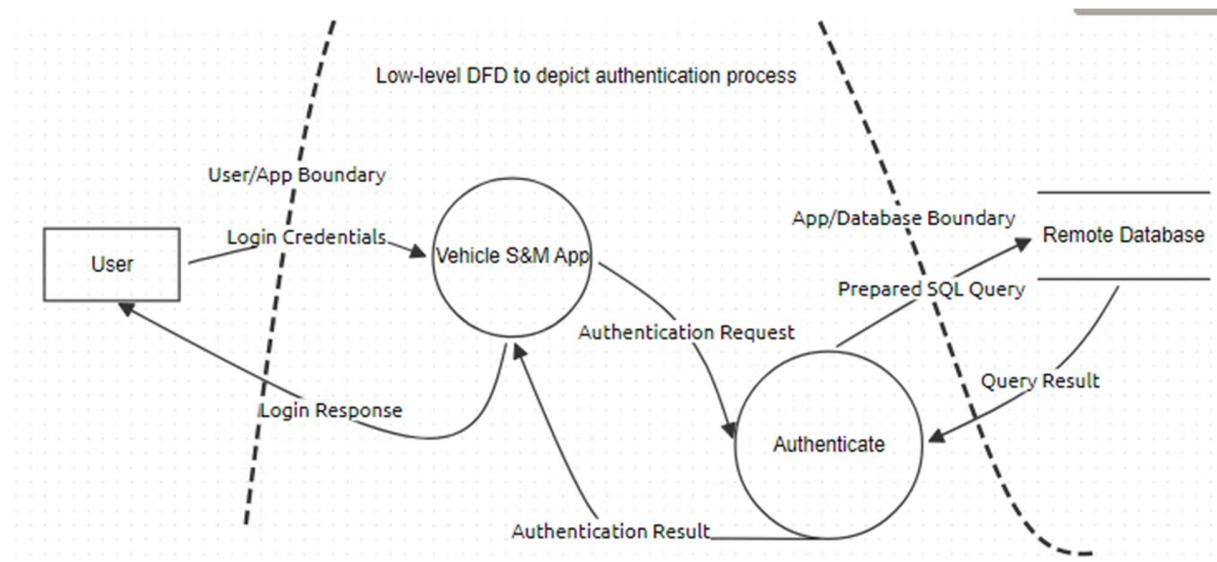
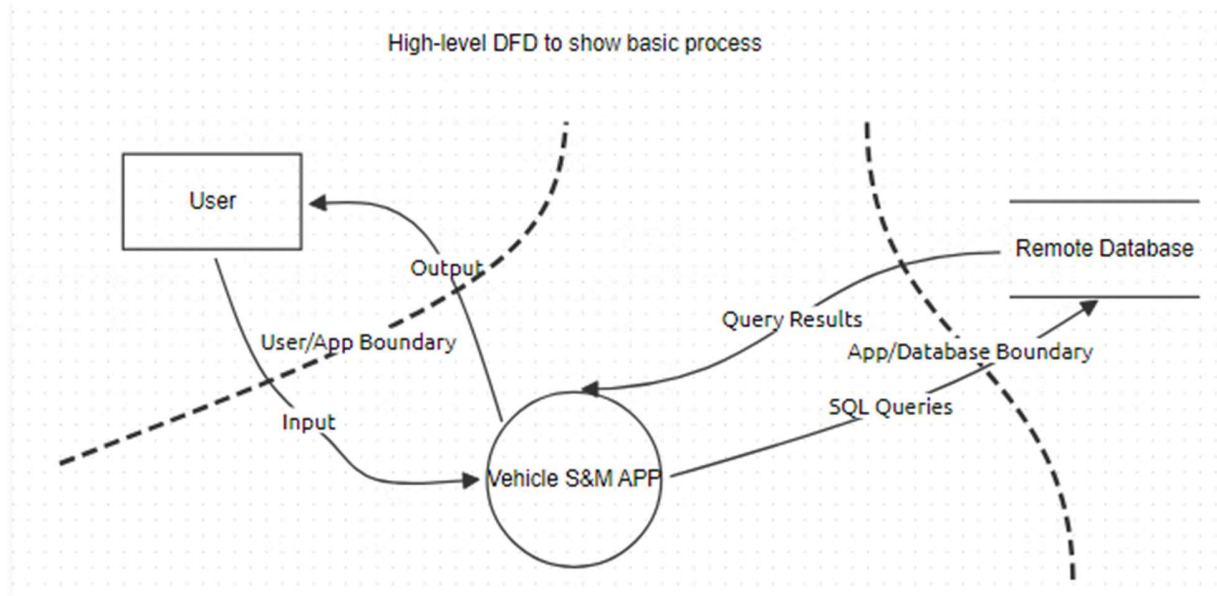
Entry/Exit points

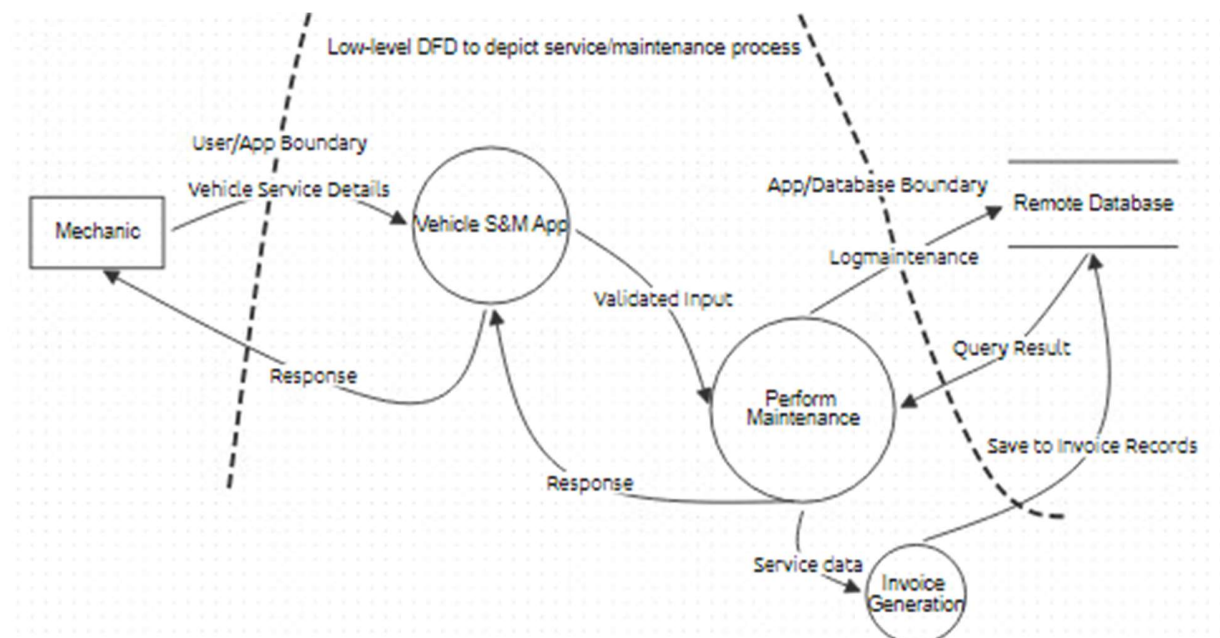
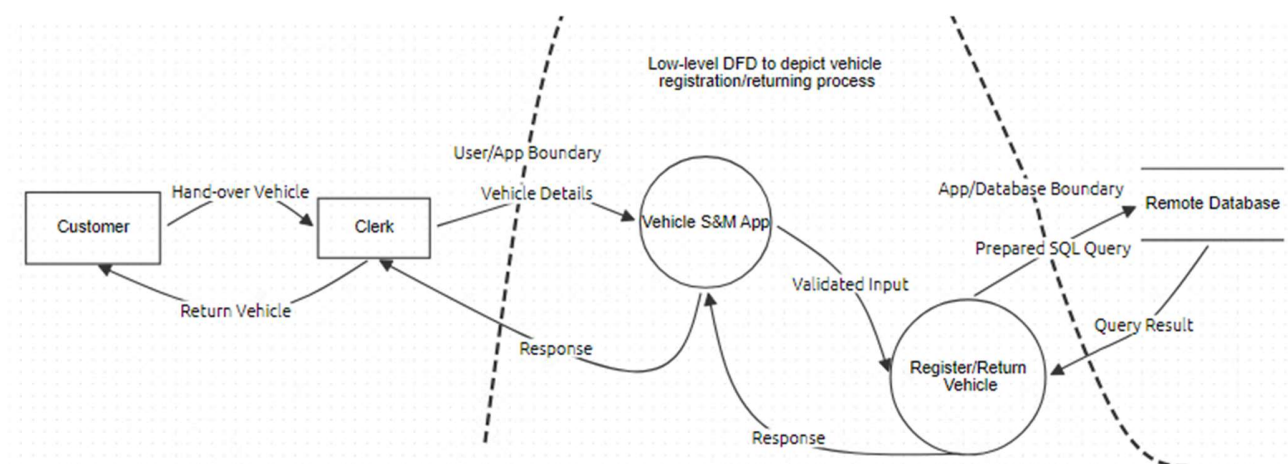
Entry/Exit Point	Trust Level
Login Interface	Low
Registration Interface	Medium
Payment Interface	Medium
Admin Panel	High
Maintenance Interface	Medium
Spare parts Interface	Medium

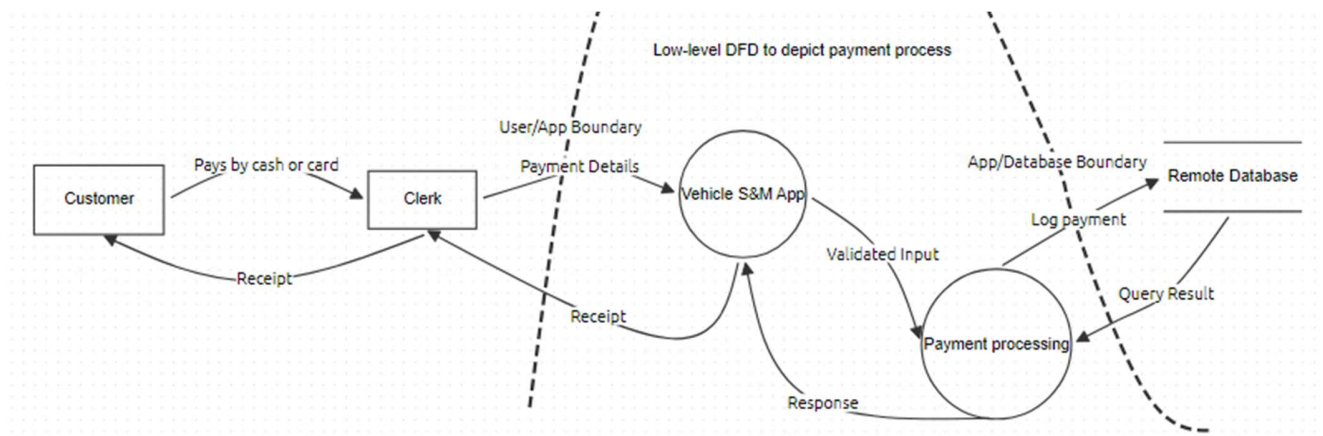
Assets

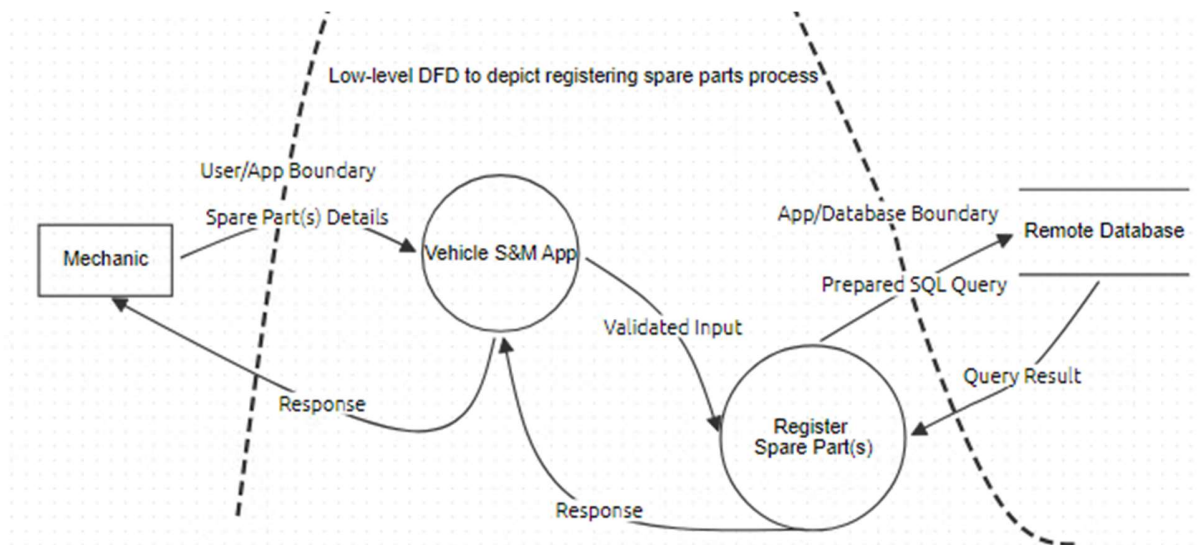
S.No.	Assets:
1	User Credentials
2	Vehicle Data
3	Maintenance Records
4	Spare Parts Inventory
5	Payment Records
6	Application Source Code

Data Flow Diagrams









Determine and Rank Threats

STRIDE

Threat Category	Threat Description
Spoofing	Attacker impersonates a user and gains access to the system
Tampering	User manipulates service or payment records for malicious purposes
Repudiation	User denies making a change in the system
Information Disclosure	Attacker leaks user credentials/credit card info
Denial of Service	SQL injection or multiple login failures
Elevation of Privilege	Clerk/Mechanic user type gains supervisor privileges

DREAD

Threat	D	R	E	A	D	Total	Rating
--------	---	---	---	---	---	-------	--------

Attacker impersonates a user and gains access to the system	3	1	2	2	2	10	Medium
User manipulates service or payment records for malicious purposes	2	1	1	2	2	8	Medium
User denies making a change in the system	3	2	3	2	3	13	High
Attacker leaks user credentials/credit card info	2	2	2	3	2	11	Medium
SQL injection or multiple login failures	1	1	1	3	2	8	Medium
Clerk/Mechanic user type gains supervisor privileges	3	1	2	3	1	10	Medium

Determine Countermeasures and Mitigation

Threat Description	Attacker impersonates a user and gains access to the system
Threat Target	User authentication process
Risk	Medium
Attack Techniques	Brute force, phishing, session hijacking
Countermeasures	Multi-factor authentication and session timeout

Threat Description	User manipulates service or payment records for malicious purposes
Threat Target	Maintenance Database, Invoice Database & Payment Records
Risk	Medium
Attack Techniques	SQL injection, parameter tampering
Countermeasures	Prepared statements, input validation and access control

Threat Description	User denies making a change in the system
Threat Target	Payment Status, Vehicle Status, Maintenance Database
Risk	High
Attack Techniques	Repudiation, log tampering
Countermeasures	Use logs protected with digital signatures to prevent tampering

Threat Description	Attacker leaks user credentials/credit card info
Threat Target	User credentials and payment information
Risk	Medium
Attack Techniques	Phishing, malware, data breach
Countermeasures	Encrypt data at rest and in transit, also use HTTPS

Threat Description	SQL injection or multiple login failures
Threat Target	Database and application availability
Risk	Medium
Attack Techniques	SQL injection, physical access to servers
Countermeasures	Prepared statements, input validation, restrict physical access

Threat Description	Clerk/Mechanic user type gains supervisor privileges
Threat Target	Full access of the application
Risk	Medium
Attack Techniques	Privilege escalation, broken access control, session hijacking
Countermeasures	Enforce role-based access control (RBAC) and validate user permissions on every request

Part 4 – Testing

SonarQube was installed in the IntelliJ IDEA to perform SAST

Test case	
Test Case ID	TC-UM-01
Requirement	UM-001 (Register user)
Description	Verify a user is registered successfully
Preconditions	Supervisor is logged in
Actions taken in the test	A supervisor registers a user by the details of the user and clicks Register User
Expected Result	A user is registered in the database and they can log in
Actual Result	A user is registered in the database and they can log in
Status	Pass

Peer-review: The inputs are sanitized and code looks alright

SAST: Maintainability flags for multiple reused variables to be declared as constants

Test case	
Test Case ID	TC-UM-02
Requirement	UM-002 (Deactivate user)
Description	Delete a user successfully from the database
Preconditions	Supervisor is logged in
Actions taken in the test	A supervisor deletes a user by clicking Deactivate User
Expected Result	A user is deleted from the database and they cant log in
Actual Result	A user is deleted from the database and they cant log in
Status	Pass

Peer-review: Pass

SAST: Maintainability flags for reused variable(s) to be declared as constants

Test case	
Test Case ID	TC-UM-03
Requirement	UM-003 (View users)
Description	Displays all users in the database and their roles
Preconditions	Supervisor is logged in
Actions taken in the test	A supervisor views all users by clicking View Users
Expected Result	All user data is retrieved from the database and displayed on the app
Actual Result	All user data is retrieved from the database and displayed on the app
Status	Pass

Peer-review: Pass

SAST: Maintainability flags for multiple reused variables to be declared as constants

Test case	
Test Case ID	TC-MI-01
Requirement	MI-001 (Register Vehicle)
Description	Clerk registers a new vehicle into the maintenance system with details like VIN, make, and model
Preconditions	Clerk must be logged in
Actions taken in the test	Clerk selects "Register Vehicle" and enters the vehicle's details, System validates and saves the record
Expected Result	Vehicle is successfully added to the database
Actual Result	Vehicle is successfully added to the database
Status	Pass

Peer-review: Pass

SAST: Maintainability flags for multiple reused variables to be declared as constants

Test case	
Test Case ID	TC-MI-02
Requirement	MI-002 (Return Vehicle)
Description	Clerk returns a serviced vehicle
Preconditions	Clerk must be logged in Vehicle must be serviced Service is paid for

Actions taken in the test	Clerk selects Return vehicle and system verifies the preconditions
Expected Result	Vehicle is successfully returned (deleted from database)
Actual Result	Vehicle is successfully returned (deleted from database)
Status	Pass

Peer-review: Pass

SAST: Maintainability flags for multiple reused variables to be declared as constants

Test case	
Test Case ID	TC-MI-03
Requirement	MI-003 (Process Payment)
Description	Clerk processes payment for maintenance/services
Preconditions	Clerk must be logged in Vehicle must be registered Service details must be logged
Actions taken in the test	Clerk selects "Process Payments" and selects the payment method, a pair of receipt is generated, one for the customer and for record-keeping
Expected Result	Payment status marked "true" for the invoice
Actual Result	Payment status marked "true" for the invoice
Status	Pass

Peer-review: Pass

SAST: Maintainability flags for multiple reused variables to be declared as constants

Test case	
Test Case ID	TC-MI-04
Requirement	MI-004 (Log In)
Description	User logs into the system with credentials
Preconditions	User has valid account
Actions taken in the test	User enters credentials, system verifies the credentials and user gains access
Expected Result	Logs in to the appropriate interface according to their role
Actual Result	Logs in to the appropriate interface according to their role

Status	Pass
--------	------

Peer-review: Pass

SAST: Maintainability flags for multiple reused variables to be declared as constants

Test case	
Test Case ID	TC-MI-05
Requirement	MI-005 (Set Vehicle Status)
Description	Update a vehicle's status (Awaiting Service/Scheduled/Ready for Pickup)
Preconditions	Vehicle is registered in the system
Actions taken in the test	System/App sets vehicle status after a certain action (example: Vehicle is registered and status is set to 'Awaiting Service')
Expected Result	Status is updated in the system
Actual Result	Status is updated in the system
Status	Pass

Peer-review: Pass

SAST: Maintainability flags for multiple reused variables to be declared as constants

Test case	
Test Case ID	TC-MI-06
Requirement	MI-006 (Register spare part)
Description	Mechanic adds a new spare part to the system inventory database
Preconditions	Mechanic is logged in
Actions taken in the test	Clerk selects "Register Spare Part", enters part's details and clicks register part
Expected Result	Database gets updated with part and the quantity
Actual Result	Database gets updated with part and the quantity
Status	Pass

Peer-review: Pass

SAST: A select statement ("SELECT *") is used and I was flagged as we should only retrieve what we need and not use the asterisk, Maintainability flags for multiple reused variables to be declared as constants

Mitigation: The asterisk was removed and the necessary column names were used

Test case	
Test Case ID	TC-MI-07
Requirement	MI-007a (Schedule maintenance)
Description	Assign a future maintenance date for a vehicle
Preconditions	Vehicle is registered and status is "Awaiting Service."
Actions taken in the test	Mechanic selects "Schedule maintenance.", chooses date/time and system confirms and makes a record in the schedule table in the database with the date
Expected Result	Appointment appears in the database
Actual Result	Appointment appears in the database
Status	Pass

Peer-review: Pass

SAST: Maintainability flags for multiple reused variables to be declared as constants

Test case	
Test Case ID	TC-MI-08
Requirement	MI-007b (Perform maintenance)
Description	Records that maintenance is done
Preconditions	Vehicle is registered and status is "Scheduled"
Actions taken in the test	Mechanic selects "Perform maintenance.", selects the vehicle to perform maintenance on, inputs the details of maintenance done.
Expected Result	Appointment appears in the database
Actual Result	Appointment appears in the database
Status	Pass

Peer-review: Pass

SAST: Maintainability flags for multiple reused variables to be declared as constants

Test case	
Test Case ID	TC-MI-09
Requirement	MI-008 (Track Spare Part used)
Description	Records spare parts used during maintenance

Preconditions	Mechanic selects parts during "Perform Maintenance"
Actions taken in the test	When mechanic selects "Perform maintenance", he to selects a part and the quantity used. The amount gets deducted from the inventory (database)
Expected Result	Spare parts records are updated
Actual Result	Spare parts records are updated
Status	Pass

Peer-review: Pass

SAST: Maintainability flags for multiple reused variables to be declared as constants

Test case	
Test Case ID	TC-MI-10
Requirement	MI-009 (View Vehicles)
Description	Displays all vehicles registered in the database and their status
Preconditions	A vehicle is registered
Actions taken in the test	A user clicks on view vehicles and all vehicles are displayed
Expected Result	All vehicles are displayed
Actual Result	All vehicles are displayed
Status	Pass

Peer-review: Pass

SAST: Maintainability flags for multiple reused variables to be declared as constants

Test case	
Test Case ID	TC-CD-01
Requirement	DBUtils
Description	Connects the application to the database
Preconditions	Database exists, credentials are correct
Actions taken in the test	Any valid action in the app opens a connection to the database
Expected Result	Successful Connection
Actual Result	Successful Connection

Status	Pass
--------	------

Peer-review: There was hard-coded credentials for connecting to the database

Mitigation: Created a .properties file in the project root. Credentials and database url are retrieved from that file using InputStream and Properties libraries. **In a normal use case scenario, the config file would have been added to the .gitignore file, but for assessment purposes, we have included this file in the github repo and submission**

SAST: A method did not close database connection after opening it

Mitigation: a close connection statement at the end of the try block of the method